

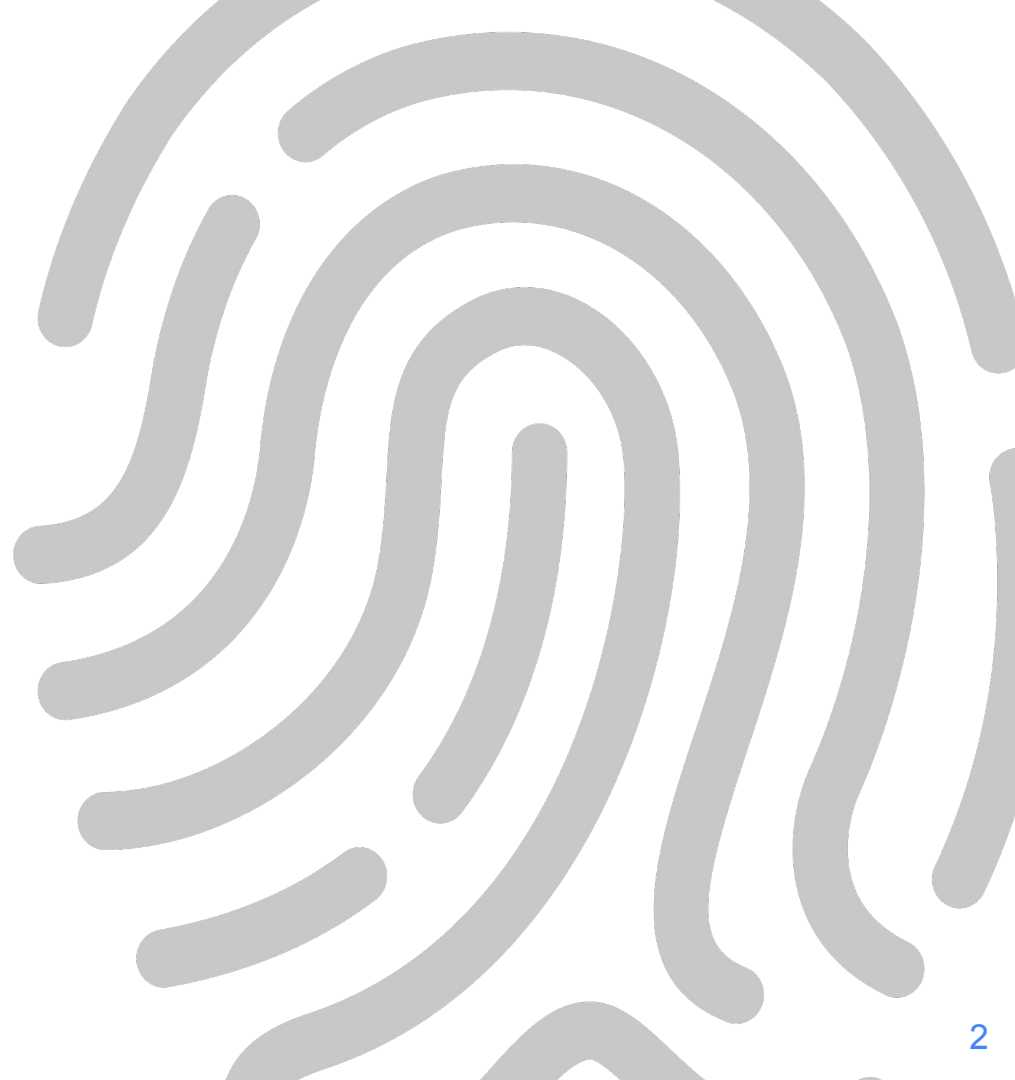
VPN

Les réseaux privés virtuels



VPN

- Ça sert à quoi ?
- Comment ça marche ?





Plan

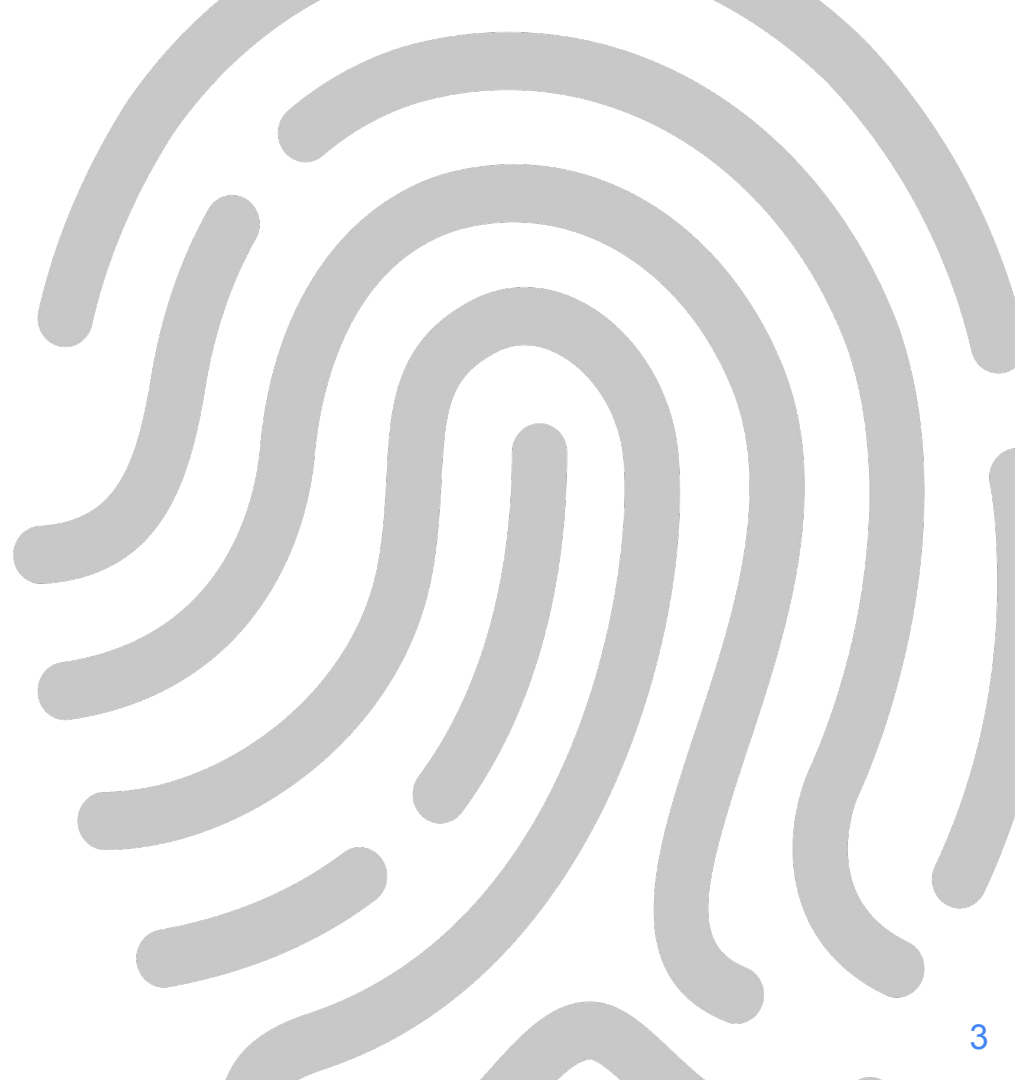
[1 - Le concept de VPN](#)

[2 - IPsec](#)

[3 - TLS](#)

[4 - OpenVPN](#)

[5 - Aller plus loin](#)





Le concept de VPN



VPN - Virtual Private Network

Un réseau privé virtuel (VPN) consiste à simuler un réseau privé en se basant sur des réseaux réels quelconques et donc éventuellement publiques comme Internet.

Objectif : fournir un accès aux ressources d'un système d'information

- Transparent
- Même niveau de sécurité
- Malgré la traversée de réseaux publiques

En résumé : Faire *comme si* on était sur le réseau local



La notion de tunnel

Un tunnel est un passage sûr à travers un réseau

=> Un VPN est constitué d'un tunnel

Encapsulation de protocoles

- Considérer le PDU à transmettre comme une donnée
- Chiffrement et authentification (en général)
- Transmission dans un autre PDU

VPN de différents niveaux (OSI) en fonction du type de PDU qu'on transporte

- Trame => VPN de niveau 2
- Paquet => VPN de niveau 3



Les types de VPN

VPN site à site

VPN accès distant (*remote access* ou *host-to-network*)

VPN point à point (*host-to-host*)



VPN site à site

- Interconnexion de réseaux physiques
- Les extrémités sont des passerelles

Exemple : une entreprise à Paris possède une filiale à Montréal.

=> On connecte 2 groupes d'ordinateurs, de façon permanente et (surtout) sans qu'aucun utilisateur n'ait rien à faire à son niveau.

Transparent pour les utilisateurs : ils travaillent sur le même intranet comme s'ils étaient côte à côte.



VPN accès distant

=> Une machine accède à un réseau.

Exemple : Un employé en télétravail a besoin d'accéder à une console de gestion.

Sa machine se connecte au réseau, via un tunnel chiffré, et l'utilisateur décide quand activer ou couper la connexion.

Utilisable de n'importe où, même d'un emplacement wifi non-sécurisé !



VPN point à point

=> Le tunnel ne permet la communication qu'entre deux machines

Exemple : Un administrateur doit se connecter uniquement à un serveur précis sans exposer le reste du réseau.



Les solutions techniques

Tous les tunnels ne sont pas des VPN sécurisés !

VPN sécurisés :

- **IPsec** : fonctionnalités additionnelles directement dans IP
- **OpenVPN** : solution basées sur TLS
- [WireGuard](#)

Tunnel seul : [L2TP](#), [GRE](#)

VPN opérateur non-chiffré : [MPLS](#)

Tunnel (ponctuel) : SSH



IPsec



IPsec

Internet Protocol Security - Ensemble de standards IETF de 1995

- Options du protocole IP créés avec IPv6 mais utilisables aussi en IPv4
- Constitué de 3 protocoles :
 - **IKEv2** - *Internet Key Exchange* : Négociation d'une communication IPsec
 - **AH** - *Authentication Headers* : Authentification et contrôle d'intégrité
 - **ESP** - *Encapsulating Security Payloads* : Confidentialité + Authentification et contrôle d'intégrité
- Permet la sécurisation de communication directement au niveau IP (3)
 - IKEv2 négocie à l'établissement de la communication
 - Choix de AH seul, ESP seul, ou AH + ESP



IKE

IKEv2 (*Internet Key Exchange*) - [RFC 7296](#)

- remplace IKE et ISAKMP (*Internet Security Association and Key Management Protocol*)
- Négocie l'établissement d'une connexion
 - Mise en place d'un canal confidentiel (Diffie-Hellmann)
 - Négociation des paramètres cryptographiques
 - Authentification mutuelle via clé partagée (*Pre-Shared Key* - PSK) ou certificats
- Communication UDP port 500 (et 4500 [NAT traversal](#))



AH

AH (*Authentication Header*) - [RFC 4302](#)

- Mécanisme d'authentification et intégrité du paquet IP type [HMAC](#)
 - Ajout d'un ICV (*Integrity Check Value*) calculé sur :
 - Le contenu (PDU)
 - L'entête AH
 - L'entête IP encapsulant AH (partie fixe)
 - Numéro de séquence => Protection contre le rejeu
- Numéro de protocole : [51](#)



ESP

ESP (*Encapsulated Security Payload*) - [RFC 4303](#)

- Le PDU est chiffré avec un algorithme symétrique
- ICV (*Integrity Check Value*) calculé uniquement sur :
 - Le contenu chiffré
 - L'entête ESP
- Numéro de séquence => Protection contre le rejeu
- Numéro de protocole : [50](#)



Les modes tunnel et transport

Les protocoles AH et ESP sont des options d'IP

- Entêtes supplémentaires qui s'intercalent entre IP et le protocole transporté
- Ex : TCP dans IP => TCP dans ESP dans IP

Mode transport :

- Le protocole de niveau 4 circule dans AH/ESP puis dans IP
- Les entêtes IP circulent en clair sans authentification/intégrité

Mode tunnel :

- Un paquet IP complet est encapsulé dans AH/ESP puis dans un (autre) IP
- L'ensemble du paquet IP encapsulé est authentifié, intègre et (éventuellement) chiffré (ESP)



IPsec & Cryptographie

IPsec assure :

- Authentification et contrôle d'intégrité
- Confidentialité
- Protection contre le rejeu

Utilisation de cryptographie

- Supporte algorithmes/cryptosystèmes différents (et évolutions possibles)
- Besoin d'une gestion de clés symétriques et/ou asymétriques



Security Association (SA)

Un noeud IPsec échange potentiellement avec de nombreux autres noeuds
Chaque noeud supporte des cryptosystèmes/paramètres potentiellement différents

Chaque communication nécessite donc un choix concernant :

- Les cryptosystèmes (et paramètres associés) utilisés pour ces paquets
- Les clés nécessaires
- L'utilisation d'AH et/ou ESP
- Mode tunnel ou transport

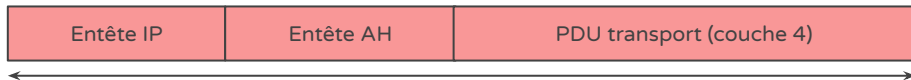
Ces informations constituent une association de sécurité (SA)

- SPI (*Security Parameter Index*) : Identifiant de la SA pour le destinataire (présent dans les entêtes AH et ESP)



Le mode transport

AH en mode transport



Authentifié et intègre (champs fixes)

ESP en mode transport



Chiffré

Authentifié et intègre

Mode transport

- Entre expéditeur et destinataire finaux (Hôte à hôte)
- Protège le protocole de transport (TCP, UDP, ...)



Le mode tunnel

AH en mode tunnel



Authentifié et intègre (champs fixes)

ESP en mode tunnel



Chiffré

Authentifié et intègre

Mode tunnel

- Entre intermédiaires (routeurs)
- Protège l'ensemble du paquet IP



IPsec en résumé

IPsec sécurise les communications directement au niveau IP (couche 3)

- Transparent pour les applications et les utilisateurs
- Authentification, intégrité, et confidentialité (avec ESP)
- Permet de sécuriser n'importe quel protocole supérieur (TCP, UDP, ICMP, etc.)
- Utilisé pour sécuriser les com. éq. rés. (routeur, pare-feu, matériel VPN, etc.)
- Protocole courant des boitiers VPN propriétaires



IPsec en résumé (suite)

2 modes de fonctionnement.

Mode transport (couche 4) :

- Protège le protocole de transport (TCP/UDP)
- Communication hôte -> hôte
- Usage limité

Mode tunnel (couche 3) :

- Encapsule et protège un paquet IP
- Communication passerelle -> passerelle ou client -> passerelle
- Très utilisé



TLS



Transport Layer Security

TLS est le successeur de SSL (*Secure Sockets Layer*)

- SSL : protocole développé par [Netscape](#) pour sécuriser HTTP
- Repris par IETF sous le nom TLS en 1999 ([TLS 1.0 - RFC 2246](#))

Protocole de transport (couche 5-6 OSI) : sécurisation de protocoles applicatifs

- Authentification par certificats du client et du serveur
- Contrôle d'intégrité et protection contre le replay
- Confidentialité persistante ([Perfect Forward Secrecy - PFS](#))

TLS se place au dessus de TCP ou d'UDP (DTLS - [RFC 9147](#))



Les versions

SSL 1.0, SSL 2.0 et SSL 3.0

- Version de travail non publiée (1.0) ou dépréciées ([RFC 6176](#) et [RFC 7568](#))

TLS 1.0 puis TLS 1.1

- Dépréciés ([RFC 8996](#))

TLS 1.2 ([RFC 5246](#)) et DTLS 1.2 ([RFC 6347](#))

- Utilisable pour des raisons de compatibilité

TLS 1.3 ([RFC 8446](#)) et DTLS 1.3 ([RFC 9147](#))

- Versions recommandées



Négociation TLS

L'établissement d'une connexion TLS nécessite :

- Établissement d'une connexion confidentielle (via [ECDH](#))
- Négociation de la version TLS, des cryptosystèmes et paramètres
- Authentification du serveur (via certificat [X.509](#) en général)
- Authentification du client (optionnelle)

Ce genre de négociation est appelé [handshake](#) ou poignée de main

Plus de détails : [The Illustrated TLS 1.3 Connection](#)



Communication TLS

Une fois la connexion établie

- Échanges confidentiels via algo et clé symétrique obtenus au handshake (ex : AES 128 bits)
- Intégrité et authenticité assurées via HMAC



Implémentation TLS

Nombreuses bibliothèques logicielles qui implémentent TLS

Les plus courantes :

- [OpenSSL](#)
- [GnuTLS](#)
- [LibreSSL](#)
- [SChannel](#) - Implémentation Microsoft pour Windows



Utilisations de TLS

- HTTP over TLS => HTTPS (TCP 443)
- FTP over TLS => FTPS (TCP 989 et 990)
- SMTP over TLS => SMTPS (TCP 465 et 587)
- POP3 et IMAP over TLS => POP3S (TCP 995) IMAPS (TCP 993)
- DNS over TLS => DoT (TCP et UDP 853)
- OpenVPN : Outils de création de VPN basé sur TLS

Plus de détails et recommandations : [Recommandations TLS](#) de l'ANSSI



OpenVPN



OpenVPN

Logiciel VPN libre client/serveur

- Basé sur TLS
- Publié initialement en 2001
- Multiplateforme
- Basé sur UDP (DTLS) ou TCP port standard 1194
- Version 2.5.8 - 2 novembre 2022
- Permet la mise en place de tunnel de niveau 2 (pont) ou 3 (routeur)



Authentification

Lors de la connexion entre le client et le serveur, établissement du tunnel :

OpenVPN procède à une authentification :

- Avec login/mot de passe
- À l'aide d'un secret partagé (Pre-Shared Key - PSK)
- Via des certificats X.509 en se basant sur une Infrastructure à clés publiques (Public Key Infrastructure)
- Autre...

Du client par le serveur et du serveur par le client (plutôt sans mot de passe...)

La configuration classique est l'authentification par certificats.



L'infrastructure à clés publiques

Pour le déploiement de VPN, il est courant de mettre en place sa propre PKI, au lieu de faire appel à une autorité de certification externe (Sauf pour l'ouverture d'un service VPN grand public)

- Création d'un certificat (clés publiques) et d'une clé privée de certification
- Recommandation : création et stockage sur une machine hors ligne
- Pour chaque serveur et chaque client :
 - Création d'un *Certificate Signing Request* (CSR)
 - Certification par l'AC
 - Déploiement du certificat serveur/client + certificat AC sur le serveur/client (attention à la clé privée !)

Peut-être facilité par [Easy-rsa](#)



Révocation

Dans le cas de compromissions de certains certificats, il peut être utile d'avoir prévu un mécanisme d'invalidation qui peut être :

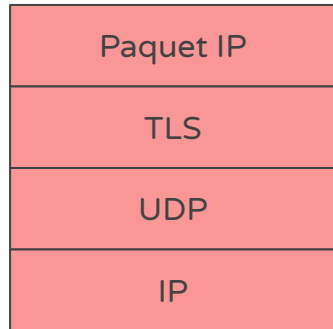
- Manuel via la création et le déploiement d'une liste de révocation ([CRL](#) - Certificate Revocation List)
- Automatique via [OCSP](#)



Mode routeur

OpenVPN peut fonctionner en mode routeur

- Création de pseudo-interfaces **tun** sur le client et le serveur
- Ces **interfaces** se comportent comme **2 ports** d'un **même routeur**
- Les **paquets IP** arrivant sur une interface sont transmis à travers le tunnel à l'autre extrémité

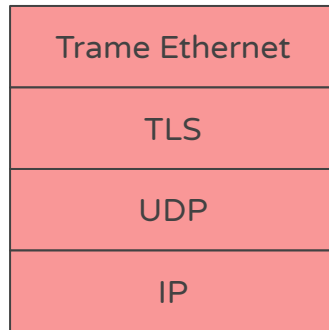




Mode pont

OpenVPN peut fonctionner en mode pont

- Création de pseudo-interfaces **tap** sur le client et le serveur
- Ces **interfaces** se comportent comme **2 ports** d'un même **pont** (switch)
- Les **trames ethernet** arrivant sur une interface sont transmis à travers le tunnel à l'autre extrémité





OpenVPN en résumé

OpenVPN permet l'interconnexion via VPN de sites ou d'hôtes

- En mode routeur (niveau 3) ou pont (niveau 2)
- Nécessite l'établissement d'une connexion (en général manuel) du client vers le serveur
- Protocole courant pour la mise en place de VPN
- Serveur OpenVPN présent sur nombreux routeurs/firewall



Aller plus loin



Serveur bastion

Le principe du bastion est une brique de sécurité, pas un protocole.

- Point d'accès unique et contrôlé vers les ressources internes
- Uniquement pour les accès d'administration

Objectifs :

- Réduire la surface d'attaque
- Centraliser les accès
- Améliorer la traçabilité



Exemple de serveur bastion

Apache Guacamole

Azure Bastion



Jump server

Bastion simple !

C'est un serveur intermédiaire, on s'y connecte avant d'accéder aux serveurs internes.

Permet un accès indirect donc meilleure maîtrise.

Rmq :

- Tous les jump servers sont des bastions
- Tous les bastions ne sont pas de simples jump servers



Exemple de jump server

Serveur SSH

Serveur RDP



Conclusion

- Concept de VPN
- Aperçu du protocole IPsec
- Aperçu d'OpenVPN et du protocole TLS

Attention :

- la mise en place de VPN ouvre une brèche entre des réseaux
=> Authentification robuste, surveillance particulière et éventuellement cloisonnement réseau particulier.